第七课 网络攻击与防范

网络攻击概述

网络入侵 VS 网络攻击

1、网络入侵

对信息系统的**非授权访问**，以及未经许可在信息系统中进行的**操作**。

👉 强调“**突破边界**”。

2、网络攻击

攻击仅仅发生在**入侵行为完成**，且入侵者已在目标网络中，指**可能使网络系统受到破坏的所有行为**（广义观点）

👉 强调“**造成后果**”。

主动攻击 VS 被动攻击

1、主动攻击

攻击者为了实现攻击目的，主动对需要访问的信息进行**非授权的访问**行为

👉 不仅获取信息，还会**修改、删除、植入数据或破坏系统**。

攻击者会通过各种手段（如伪装、欺骗、植入恶意程序等）与目标系统进行直接的交互，从而直接干扰系统的正常运行或破坏数据的完整性

常见攻击：

- **冒充**：伪装成合法用户身份，从而骗过系统权限限制
- **重放**：复制合法的通信数据，并将其重新发送给系统。
- **篡改**：直接修改合法用户传输的数据内容，破坏数据的完整性
- **拒绝服务攻击**（DoS）：发送大量无效请求，占用系统的关键资源
- **内部攻击**：拥有合法内部权限的人员发起的破坏行为
- **外部攻击**：通过旁路、截获信号等物理或逻辑手段，从系统外部进行的攻击
- **陷阱门**：预先植入“后门”程序
- **特洛伊木马**：伪装成正常、有用程序的恶意软件
- **社会工程学**

2、被动攻击

利用网络存在的漏洞和安全缺陷，对硬件、软件及数据进行的攻击

👉 它侧重于“**收集**”和“**分析**”，一般**不会对数据进行篡改**。通过截取、窃听或流量分析等方式，在未经用户授权的情况下获取信息内容或分析业务数据流

常见攻击：

- **窃听**：获取明文或密文信息
- **流量分析**：通过数据拦截进行定向分析

Web 应用安全

SQL注入

1、原理

核心在于**输入验证不严**。攻击者在Web应用的输入框或请求参数中，**恶意插入SQL语句片段**。当应用程序将这些输入直接拼接到后台的数据库查询语句中时，数据库会“误以为”这些恶意片段是合法的查询指令并执行，从而导致数据泄露、篡改或权限提升。

2、后果

- **数据泄露**： 攻击者可以获取数据库中的**敏感数据**（如用户资料、个人隐私）。
- **篡改数据**： 攻击者可以**修改或删除数据库**中的内容。
- **权限提升**： **绕过身份验证**，以管理员身份控制整个系统。

3、常用工具

- **SQLMap**：

  一款主流的自动化SQL注入测试工具，用来检测系统中是否存在SQL注入漏洞。

XSS

跨站脚本攻击，Cross-Site Scripting

核心是攻击者将恶意脚本代码注入到网页中，当其他用户浏览该网页时，脚本就会在用户的浏览器上执行。主要用于窃取用户信息或实施进一步的恶意行为。

1、主要类型

- **存储型XSS**：

  恶意代码被**永久性地存储**在目标服务器的数据库中（如留言板、评论区）。当任何用户访问受感染的页面时，都会触发恶意代码，这种类型的危害面最广，会**影响所有访问者**。

- **反射型XSS**：

  恶意代码**不会存储**在服务器上，而是**作为参数附加在URL链接**中。攻击者通常通过发送**恶意链接诱导用户点击**，当用户点击后，目标网站将恶意代码“反射”回用户的浏览器并立即执行脚本。

- **DOM型XSS**：

  这是一种完全基于**客户端（前端）**的攻击。它利用前端脚本代码的漏洞，直接在用户的浏览器中**操控网页的DOM结构**，从而执行恶意代码。

2、主要危害

- **窃取用户身份：** 获取用户的Cookie信息，攻击者可以利用这些Cookie直接**冒充受害者身份**，免密码登录目标网站。
- **网络钓鱼：** 可以在正常网页上伪造逼真的钓鱼页面（如弹出一个虚假的重新登录框），骗取用户的账号和密码。
- **恶意传播：** 在网页中隐藏恶意链接，使其像蠕虫一样继续攻击其他正常访问该页面的用户。

3、常用工具

- **BeEF**

  攻击工具，**XSS漏洞利用框架**

- **XSSer**：

  一款自动化框架，专门用于检测、绕过过滤器并利用Web应用程序中的跨站脚本（XSS）漏洞

文件上传漏洞

1、原理

由于Web应用没有对用户上传的文件进行严格的安全验证，导致攻击者能够**绕过上传限制**，将**恶意脚本文件**（通常称为 **WebShell**，即网页后门）上传到服务器。一旦上传成功，攻击者就可以在浏览器端通过访问该文件，在服务器端执行任意命令，从而实现**对服务器**的**远程控制**。

2、主要危害

- **获取服务器控制权：** 通过WebShell控制后台系统，窃取服务器上的机密数据。
- **网页挂马与篡改：** 恶意修改网站首页，影响企业声誉（见第53页）。
- **作为跳板：** 利用被控制的服务器对内部网络（内网）进行进一步渗透或发起DDoS攻击。

3、常用攻击

- **BurpSuite**：

  测试文件上传漏洞最常用的工具，安全人员常通过它的抓包、改包功能，来验证和调试上传点的安全防御能力。

CSRF

Cross-Site Request Forgery，跨站请求伪造

1、原理

攻击者诱导用户在“已登录状态下”访问恶意页面，从而“借用户身份”执行非本意操作

2、主要危害

- 篡改账户数据、配置
- 冒充合法用户进行资金交易
- 获取非法权限
- 恶意修改网页，发布虚假内容

IDS和IPS特点比较

1、IDS 入侵检测系统

基本定义：对入侵行为进行**识别与报警**的系统，**发现攻击，但不阻断**

工作方式：**被动检测**

- 监听网络流量或主机日志
- 分析是否存在攻击
- 发现攻击 → **报警**

部署位置：“**旁路监控**”

- 防火墙后面
- 内网关键节点

检测模型：

- 误用检测模型（基于特征库）：通过与攻击模式或攻击签名匹配来判断入侵行为，能准确检测已知攻击（基于行为）
- 异常检测模型

2、IPS 入侵防御系统

基本定义：是 IDS 的升级版，不仅检测，还可以**主动阻断攻击**

工作方式：**主动防御**

- 实时监控进出流量
- 检测攻击特征
- 发现攻击 → **直接丢弃/阻断数据包**

部署位置：**“串联阻断设备”**

- 网络入口（串联方式）
- 类似防火墙位置